GESTIÓN DE VULNERABILIDADES

Caso práctico: Elasticsearch 1.1.1 en Windows Server 2012

Por: Jonathan Gomez

TIPO DE EJERCICIO	ACTIVO ANALIZADO	RESULTADO PRINCIPAL
Laboratorio controlado	Windows Server 2012 • 192.168.1.25	Acceso no autenticado a la API; servicio detenido y puerto verificado desde Kali

Propósito. Documentar un ciclo de gestión de vulnerabilidades de extremo a extremo: identificación, validación, análisis, evaluación de severidad, priorización, tratamiento, verificación y lecciones aprendidas.

Alcance ético. Todas las pruebas descritas se realizaron en un entorno de laboratorio autorizado. Los comandos de explotación se omiten de esta versión pública; se conservan las evidencias y los resultados necesarios para explicar el análisis.

1. Resumen ejecutivo

Durante el reconocimiento de un Windows Server del laboratorio se identificó Elasticsearch 1.1.1 expuesto en TCP/9200. La API respondió por HTTP sin solicitar credenciales en las peticiones realizadas, permitió enumerar índices y leer un documento de prueba. La versión observada es antigua y el análisis relacionó el servicio con CVE-2014-3120, asociada en el escenario a ejecución remota de código (RCE).

La evidencia del documento original registra una prueba controlada de explotación con apertura de una sesión Meterpreter y actividad de red asociada. Luego se terminó el proceso de la sesión, se documentó la eliminación del artefacto temporal y se detuvo el servicio Elasticsearch. Desde Kali, Nmap reportó el puerto 9200 como cerrado y curl no pudo establecer conexión. Esta verificación demuestra que el servicio dejó de aceptar conexiones en ese momento; por sí sola no demuestra que la regla de firewall se haya aplicado, ni que la vulnerabilidad de software haya sido corregida permanentemente.

Estado del caso	Conclusión
Identificación y validación	Evidencia reproducible de versión antigua y API accesible sin autenticación aparente.
Impacto	Se demostró RCE en el laboratorio según las evidencias de la sesión de prueba.
Contención / tratamiento inmediato	Sesión de prueba terminada, artefacto temporal reportado como eliminado y servicio detenido.
Verificación	Puerto 9200 cerrado desde Kali y solicitud HTTP fallida.
Pendiente para cierre definitivo	Confirmar dependencias, retirar/actualizar Elasticsearch, revisar firewall efectivo, comprobar registros y repetir el escaneo después del cambio permanente.

2. Alcance y topología

Objetivo: evaluar un servicio identificado en el servidor, confirmar la exposición y aplicar una medida de tratamiento verificable.

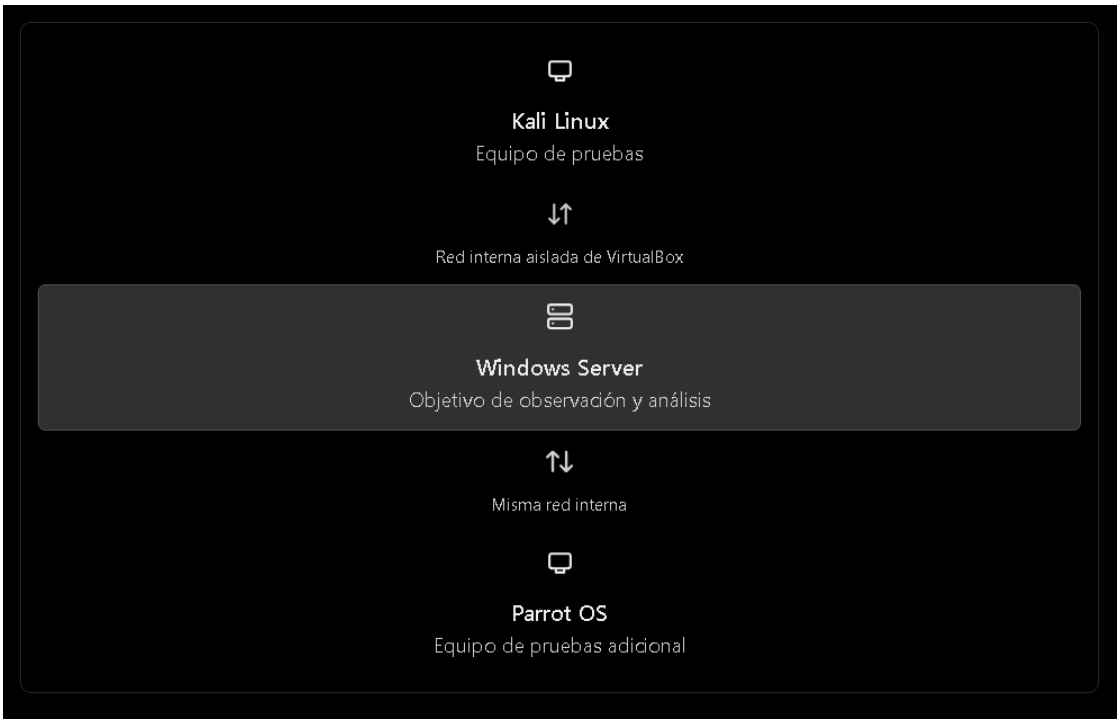


Figura 1. Topología de laboratorio representada en el documento de evidencias.

Componente	Detalle observado

Equipo de pruebas	Kali Linux
Activo objetivo	Windows Server 2012 x64 • host ENIGMA
Dirección del objetivo	192.168.1.25
Servicio	Elasticsearch 1.1.1
Puerto/protocolo	TCP/9200 (HTTP)
Contexto	Red interna de laboratorio; dominio identificado como SantaPrisca.virtual

3. Flujo de gestión aplicado

Fase	Pregunta que responde	Producto / evidencia
1. Identificar	¿Qué activos y servicios están expuestos?	Inventario de puertos y versiones.
2. Validar	¿La exposición se confirma de forma reproducible?	Respuesta HTTP, metadatos, índices y lectura de documento de prueba.
3. Analizar	¿Cuál es la causa técnica y qué puede permitir?	Versión, configuración de scripting, acceso sin autenticación y evidencia de RCE en laboratorio.
4. Evaluar severidad	¿Qué tan grave sería si se explotara?	Impacto, explotabilidad, privilegios, exposición y controles.
5. Priorizar	¿Qué debe tratarse primero?	Riesgo crítico por RCE demostrada y acceso desde otro equipo.
6. Tratar	¿Qué control reduce o elimina el riesgo?	Contención de sesión, limpieza del artefacto reportado, desactivación del servicio y plan de actualización/restricción.
7. Verificar	¿La medida funcionó?	Nmap y curl desde Kali; revisión de estado local.
8. Documentar	¿Qué se hizo y qué queda pendiente?	Hallazgo, evidencias, limitaciones y lecciones aprendidas.

4. Identificación

Se ejecutó reconocimiento de servicios con Nmap. Entre varios puertos detectados, TCP/9200 fue identificado como Elasticsearch REST API 1.1.1.

```
nmap -sV -p 9200 192.168.1.25
```

Dato	Resultado
Puerto	9200/tcp
Estado inicial	open
Servicio detectado	HTTP / Elasticsearch REST API
Versión reportada	1.1.1
Nombre de instancia	Wolfsbane
Biblioteca declarada	Lucene 4.7

La identificación de versión no demuestra por sí sola la explotabilidad; requiere validación de configuración, exposición y condiciones asociadas a la vulnerabilidad.

5. Validación técnica

5.1 Confirmación de versión y acceso a la API

```
curl -i --connect-timeout 5 http://192.168.1.25:9200/
```

La respuesta documentada fue HTTP 200 OK e incluyó la versión 1.1.1 y la fecha de compilación de 2014-04-16.

5.2 Enumeración de índices

```
curl -i --connect-timeout 5 "http://192.168.1.25:9200/_cat/indices?v"
```

La API devolvió el listado de índices sin pedir credenciales en la solicitud mostrada. Los nombres de los índices no prueban por sí solos que existan archivos o aplicaciones con esos nombres.

5.3 Lectura de un documento de prueba

```
curl -sS --connect-timeout 5 \
  "http://192.168.1.25:9200/metasploitable3/_search?pretty" \
  -H 'Content-Type: application/json' \
  -d '{"size":1,"query":{"match_all":{}}}'
```

La respuesta incluyó un documento de ejemplo: user="kimchy", post_date="2009-11-15T14:12:12", message="Elasticsearch". El dato observado confirma lectura de un documento, pero no demuestra por sí mismo exposición de información sensible.

Conclusión de validación

Se confirmó acceso de red a la API, divulgación de metadatos, enumeración de índices y lectura de al menos un documento sin autenticación aparente en las solicitudes registradas.

5.4 Evidencia de ejecución remota en el laboratorio

Además de confirmar el acceso a la API, el ejercicio registró una prueba controlada de explotación en el laboratorio. La evidencia de la consola muestra que se abrió una sesión Meterpreter hacia el equipo de pruebas. Desde esa sesión se consultaron datos básicos del sistema objetivo: identidad de la sesión (ENIGMA$), nombre del equipo (ENIGMA), sistema operativo Windows Server 2012 x64 y PID del proceso asociado a la sesión. Esto aporta evidencia de ejecución remota, más allá de la enumeración HTTP; no se incluye el procedimiento de explotación ni su código en esta versión pública.

Interpretación: la sesión obtenida confirma impacto de ejecución remota en las condiciones específicas del laboratorio. La identidad ENIGMA$ corresponde a la identidad reportada por la sesión; por sí sola no demuestra privilegios de administrador local ni de administrador de dominio. La captura debe presentarse como evidencia del resultado y no como instrucción de explotación.



Figura 2. Evidencia de la sesión Meterpreter: identidad reportada, sistema operativo y PID. Se omiten los pasos y parámetros de explotación.

Nota de trazabilidad: el documento fuente registra una sesión abierta el 11 de octubre de 2026 a las 14:29:26 EDT. La evidencia se usa para demostrar el resultado de la validación en el laboratorio; no implica que el mismo impacto se haya confirmado en otro entorno.

6. Análisis técnico del hallazgo

Campo	Detalle
ID del hallazgo	VULN-001

Título	Elasticsearch 1.1.1 expuesto; API accesible sin autenticación aparente
Activo	ENIGMA • 192.168.1.25
Servicio afectado	Elasticsearch 1.1.1 / TCP 9200
CVE asociada en el ejercicio	CVE-2014-3120
Debilidad investigada	Versión antigua y scripting dinámico MVEL señalado en la evidencia del laboratorio
Evidencia de explotación	El documento registra una sesión Meterpreter de prueba y una conexión saliente desde el objetivo al equipo Kali.
Privilegios observados	La sesión reportó la identidad de equipo ENIGMA$; debe interpretarse como identidad de la sesión obtenida, no como prueba de privilegios de administrador local o de dominio.
Artefacto reportado	C:\Windows\TEMP\UzMjr.jar

La evidencia del laboratorio vincula el servicio con CVE-2014-3120 y registra una prueba de RCE. En un informe profesional, la correspondencia exacta entre versión, CVE y configuración debe contrastarse con una fuente de vulnerabilidades del fabricante o una base reconocida antes de publicar una puntuación CVSS como definitiva.

Nota de rigor: el documento de origen presenta CVSS 10.0 como severidad. Esta versión del informe conserva la clasificación operativa como crítica debido a la RCE demostrada en el laboratorio, pero deja la puntuación oficial pendiente de verificación independiente. La salida de Nmap/Vulners enumera múltiples referencias y puntuaciones; no debe asumirse que todas corresponden a la misma CVE o a las mismas condiciones.

7. Evaluación de severidad y riesgo

Factor	Evaluación del caso	Justificación
Explotabilidad	Alta en el escenario probado	La evidencia registra ejecución remota en el laboratorio.
Autenticación	No observada en las solicitudes HTTP de validación	Las llamadas documentadas no incluyeron credenciales.
Impacto en confidencialidad	Potencialmente alto	Se pudieron enumerar índices y leer un documento; sensibilidad real no establecida.
Impacto en integridad	Alto potencial	La RCE podría permitir acciones con los privilegios del proceso comprometido.
Impacto en disponibilidad	Alto potencial	La ejecución remota puede afectar el servicio o el host.
Exposición	Accesible desde otro equipo de la red	Kali alcanzó el puerto 9200 antes del tratamiento.
Controles preventivos	Insuficientes en la situación inicial	Los perfiles del Firewall de Windows aparecieron deshabilitados durante la revisión.

Clasificación de trabajo: CRÍTICA. Basada en la ejecución remota observada en el laboratorio y en la exposición desde otro equipo. La puntuación CVSS oficial debe validarse por separado y registrarse con su versión (CVSS v2/v3/v4), vector y fuente.

8. Priorización

El hallazgo se priorizó para tratamiento inmediato porque combina software muy antiguo, API accesible desde la red, ausencia aparente de autenticación y evidencia de RCE en el laboratorio.

Prioridad	Acción	Criterio de salida
P1 — inmediata	Aislar o detener el servicio si no puede restringirse de forma segura; preservar evidencias y validar dependencias.	El servicio deja de ser accesible desde equipos no autorizados y se conserva evidencia del cambio.
P1 — inmediata	Revisar si hubo actividad adicional: conexiones, procesos, artefactos y registros de seguridad.	Alcance de la actividad documentado; incertidumbres explícitas.
P1 — alta	Planificar actualización o retirada de	Versión soportada y configuración

	Elasticsearch 1.1.1 y corregir la configuración insegura.	endurecida, validada en pruebas.
P2 — seguimiento	Configurar auditoría de creación de procesos y conexiones de plataforma; centralizar registros.	Eventos generados y visibles para revisión/correlación.

9. Tratamiento: contención y erradicación

9.1 Contención

- Se terminó el proceso de la sesión de prueba identificado en el documento original (PID 6200); posteriormente, la consulta de conexiones ya no mostró el canal registrado.
- Se documentó la eliminación del artefacto temporal C:\Windows\TEMP\UzMjr.jar. En un incidente real, primero se debe preservar la evidencia necesaria y registrar hash, fecha, ruta y responsable antes de eliminar archivos.
- Se evaluó el bloqueo de TCP/9200 mediante una regla local del Firewall de Windows. La regla se creó, pero la prueba inicial desde Kali continuó respondiendo porque los perfiles del firewall estaban deshabilitados.
- Como medida efectiva en el laboratorio, se detuvo el servicio Elasticsearch. Esto interrumpe el servicio y debe hacerse solo tras evaluar dependencias o cuando el riesgo justifique la interrupción.

9.2 Erradicación y remediación permanente

1. Retirar o actualizar Elasticsearch 1.1.1 a una versión soportada, después de revisar compatibilidad, respaldo, plan de cambio y recuperación.
2. Deshabilitar la funcionalidad vulnerable según la versión y la documentación oficial aplicable. El archivo original propone `script.disable_dynamic: true`; debe verificarse que el parámetro exista y sea efectivo en esa versión antes de tratarlo como control confirmado.
3. Restringir TCP/9200 a las direcciones estrictamente necesarias mediante firewall y/o enlazar el servicio a una interfaz de gestión autorizada.
4. Aplicar autenticación y autorización apropiadas si el servicio debe seguir accesible; no considerar el firewall como sustituto de controles de acceso de la aplicación.
5. Ejecutar Elasticsearch bajo una cuenta de servicio dedicada con privilegios mínimos, no bajo una identidad de equipo o cuenta con privilegios innecesarios.
6. Revisar la configuración de auditoría y remitir eventos relevantes a un repositorio central o SIEM.

Estado demostrado en el material: el servicio se detuvo y el puerto dejó de aceptar conexiones desde Kali. No se demuestra todavía una actualización de software ni una corrección permanente de la configuración.

10. Verificación posterior al tratamiento

10.1 Verificación local en Windows Server

```
Get-Service -Name "elasticsearch-service-x64"
```

```
netstat -ano | findstr :9200
```

Tras detener el servicio, `Get-NetTCPConnection -LocalPort 9200 -State Listen` no encontró objetos coincidentes. Esta respuesta es esperable cuando no existe un listener; no es un error de remediación.

10.2 Verificación remota desde Kali

```
nmap -Pn -p 9200 192.168.1.25
```

```
curl -i --connect-timeout 5 http://192.168.1.25:9200/
```

Prueba posterior	Resultado documentado	Interpretación
Nmap TCP/9200	closed	El host respondió, pero no había servicio escuchando en ese puerto.
curl a la API	Failed to connect / Could not connect to server	La API dejó de ser accesible desde Kali.
Reintento de explotación	No pudo establecer la conexión	La condición de acceso al servicio ya no estaba disponible en esa prueba.

Limitación: al detener el servicio, la prueba demuestra que el puerto no acepta conexiones en ese momento. Para verificar específicamente una regla de firewall, el servicio tendría que estar escuchando en una condición controlada y la prueba tendría que realizarse con el firewall habilitado; esa prueba no debe hacerse en producción sin una ventana de cambio y acceso alternativo.

11. Evidencias seleccionadas

Las siguientes capturas se incluyen como apoyo visual. En un portafolio público, deben ocultarse nombres de dominio internos, direcciones, identificadores de cuenta y cualquier dato que pueda revelar información real de una organización.

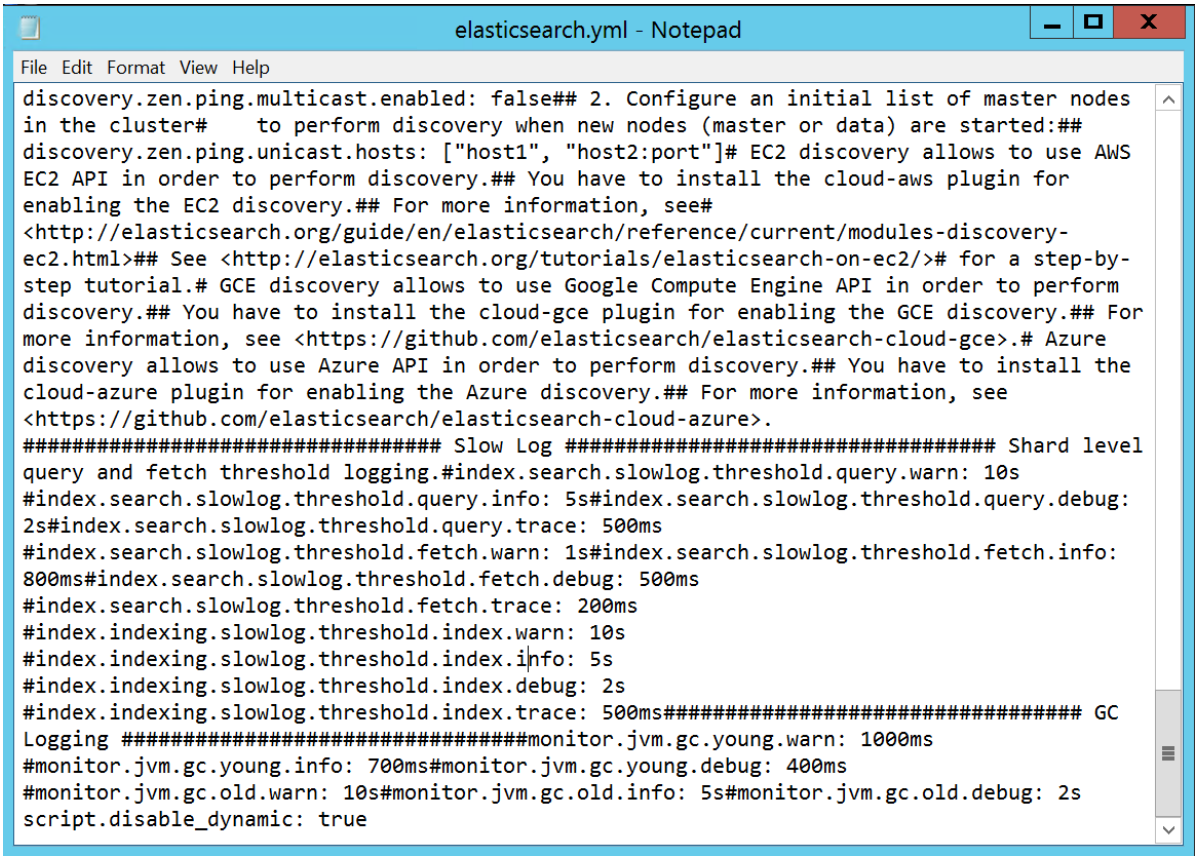


Figura 2. Configuración de Elasticsearch mostrada en el laboratorio; la línea de scripting dinámico aparece en la captura.

```
TimeCreated : 10/12/2026 10:49:55 AM
Id          : 5156
Message     : The Windows Filtering Platform has permitted a connection.

              Application Information:
                  Process ID:        1992
                  Application Name:    \device\harddiskvolume2\program
              files\elasticsearch-1.1.1\bin\elasticsearch-service-x64.exe

              Network Information:
                  Direction:         Inbound
                  Source Address:        192.168.1.25
                  Source Port:       9200
                  Destination Address:    192.168.1.100
                  Destination Port:       45559
                  Protocol:        6

              Filter Information:
                  Filter Run-Time ID:    0
                  Layer Name:        Receive/Accept
                  Layer Run-Time ID:    44
```

Figura 3. Evento de Windows Filtering Platform relacionado con una conexión hacia el servicio.

```
PS C:\Users\vagrant> taskkill /PID 6200 /F
SUCCESS: The process with PID 6200 has been terminated.
PS C:\Users\vagrant> netstat -ano | findstr 192.168.1.100
PS C:\Users\vagrant>
```

Figura 4. Evidencia de terminación de la sesión de prueba y comprobación de conexiones.

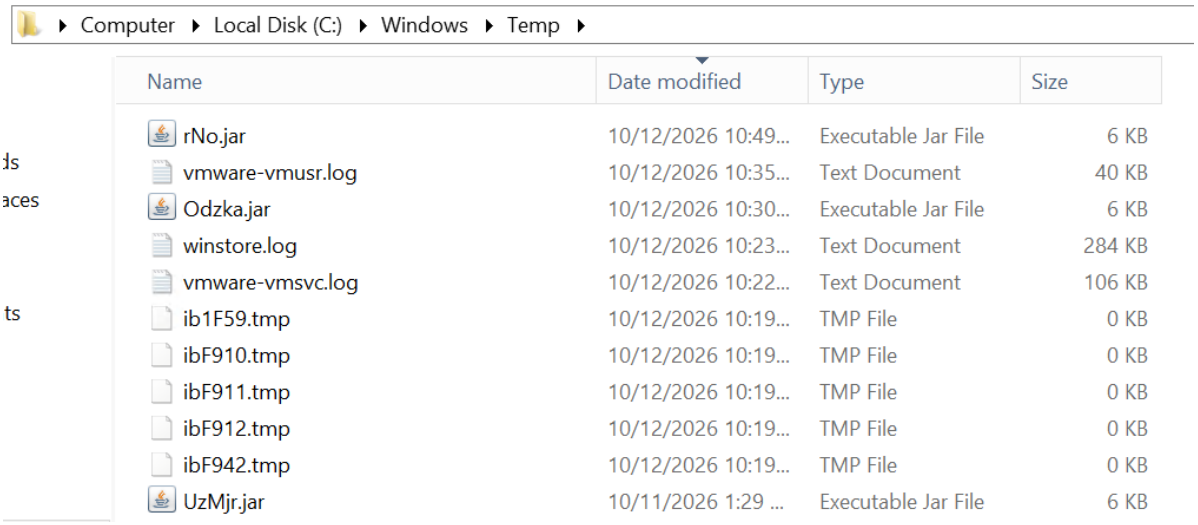


Figura 5. Evidencia visual del artefacto temporal señalado en el laboratorio.

```
┌──(kali㉿kali)-[~]
└─$ nmap -Pn -p 9200 192.168.1.25
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-12 12:31 EDT
Nmap scan report for 192.168.1.25
Host is up (0.0028s latency).

PORT     STATE  SERVICE
9200/tcp closed wap-wsp
MAC Address: 08:00:27:5D:1B:3C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.22 seconds
```

Figura 6. Resultado de Nmap posterior al tratamiento: TCP/9200 aparece cerrado.

La captura de configuración no sustituye la verificación del valor efectivo en ejecución. La captura del evento tampoco demuestra por sí sola que el sistema de auditoría estuviera completo; debe acompañarse de configuración de auditoría y correlación de eventos.

12. Lecciones aprendidas

7. Un puerto abierto y una versión antigua son indicadores que requieren validación; el riesgo se confirma evaluando accesibilidad, configuración, permisos y comportamiento.
8. No debe afirmarse que una regla de firewall es efectiva solo porque se creó. Hay que revisar que el perfil esté habilitado y verificar desde el origen de prueba.
9. La ausencia de una conexión activa no demuestra ausencia de exposición; el listener puede seguir disponible para futuras conexiones.
10. Detener un servicio es una medida de contención o mitigación temporal, no reemplaza la actualización o eliminación del software vulnerable.
11. Antes de cambiar servicios o firewall, se deben revisar dependencias y preservar el acceso administrativo, especialmente en servidores remotos.
12. La gestión de vulnerabilidades debe dejar evidencia antes/después, responsable, fecha, riesgo residual y criterio formal de cierre.
13. La auditoría de eventos y su centralización deben prepararse antes de un incidente para facilitar la reconstrucción de la actividad.

13. Registro final del hallazgo

Campo	Registro
ID	VULN-001
Activo	Windows Server 2012 x64 • 192.168.1.25
Componente	Elasticsearch 1.1.1 • TCP/9200
Hallazgo	API accesible sin autenticación aparente; exposición asociada a RCE en el laboratorio.
Severidad de trabajo	Crítica; puntuación CVSS oficial pendiente de verificar con fuente primaria.
Tratamiento ejecutado	Sesión de prueba terminada; artefacto temporal reportado como eliminado; servicio detenido.
Verificación	Nmap reportó `closed`; curl no pudo conectar desde Kali.
Riesgo residual	No se ha demostrado actualización ni retirada permanente del software. Si se vuelve a iniciar, la exposición podría reaparecer.
Criterio de cierre definitivo	Actualizar/retirar, validar configuración y dependencias, aplicar controles de acceso, revisar logs, reiniciar de forma controlada y repetir pruebas desde Kali.

14. Conclusión

El caso demuestra la aplicación de un flujo práctico de gestión de vulnerabilidades: descubrimiento, validación técnica, análisis de impacto, priorización, tratamiento y verificación posterior. La evidencia confirma que la API de Elasticsearch 1.1.1 era accesible desde la red y que el puerto dejó de aceptar conexiones desde Kali después de detener el servicio. Para declarar el hallazgo cerrado de forma permanente, aún se requiere confirmar la actualización o retirada del componente, validar los controles efectivos de red y aplicación, y documentar el riesgo residual.

Nota para publicación en portafolio: presentar el ejercicio como laboratorio controlado, no como incidente de producción. Eliminar o anonimizar nombres internos, cuentas de dominio, direcciones IP y artefactos que identifiquen el entorno antes de publicar.